

ICO Guidance on AI and Data Protection - Selected Chapters

Source URL: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/>; <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/how-do-we-ensure-transparency-in-ai/>; <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/how-do-we-ensure-lawfulness-in-ai/>; <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/what-do-we-need-to-know-about-accuracy-and-statistical-accuracy/>; <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/how-should-we-assess-security-and-data-minimisation-in-ai/>

ICO AI and Data Protection - Guidance Overview

URL: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/>

Guidance on AI and data protection | ICO Skip to main content Home The ICO exists to empower you through information. Search Search Search Menu

Guidance on AI and data protection

Contents

Search this document

This guidance was updated on 15 March 2023.

The Guidance on AI and Data Protection has been updated after requests from UK industry to clarify requirements for fairness in AI. It also delivers on a key ICO25 commitment , which is to help organisations adopt new technologies while protecting people and vulnerable groups.

This update supports the UK government's vision of a pro-innovation approach to AI regulation and more specifically its intention to embed considerations of fairness into AI .

We continue to engage with the UK government, along with our partners within the Digital Regulation Cooperation Forum (DRCF) , on its broader proposals on regulatory reform.

The ICO supports the government's mission to ensure that the UK's regulatory regime keeps pace with and responds to new challenges and opportunities presented by AI. We look forward to supporting the implementation of its forthcoming White Paper on AI Regulation.

We will continue to ensure ICO's AI guidance is user friendly, reduces the burden of compliance for organisations and reflects upcoming changes in relation to AI regulation and data protection.

For ease of use and given the foundational nature of data protection principles we decided to restructure the guidance moving some of the existing content into new chapters. Acknowledging the fast pace of technological development the ICO believes more updates will be required in the future so using data protection's principles as the core of this expanding work makes editorial and operational sense.

We outlined below where new content resides so past readers of the Guidance on AI and Data Protection can navigate the changes at speed.

What are the accountability and governance implications of AI?

Change overview : This is an old chapter with new additions

What you need to know:

New content on things to consider as part of your DPIA

How do we ensure transparency in AI?

Change overview : This is a new chapter with new content

What you need to know:

We have created a standalone chapter with new high-level content on the transparency principle as it applies to AI. The main guidance on transparency and explainability resides within our existing Explaining Decisions Made with AI product.

How do we ensure lawfulness in AI?

Change overview : This is a new chapter with old content - moved from the previous chapter titled 'What do we need to do to ensure lawfulness, fairness, and transparency in AI systems?' - and two added new sections.

What you need to know:

New content added on AI and inferences , affinity groups and special category data

What do we need to know about accuracy and statistical accuracy?

Change overview : This is new chapter with old content.

What you need to know:

Following the restructuring under the data protection principles, the statistical accuracy content – that used to reside with the chapter 'What do we need to do to ensure lawfulness, fairness, and transparency in AI systems?' - has moved into a new chapter that will focus on the accuracy principle. Statistical accuracy continues to remain key for fairness but we felt it was more appropriate to host it under a chapter that focuses on the accuracy principle.

Fairness in AI

Change overview : This is a new chapter with new and old content.

What you need to know:

The old content was extracted from the former chapter titled 'What do we need to do to ensure lawfulness, fairness, and transparency in AI systems?'. The new content includes information on:

Data protection's approach to fairness, how it applies to AI and a non-exhaustive list of legal provisions to consider.

The difference between fairness, algorithmic fairness, bias and discrimination.

High level considerations when thinking about evaluating fairness and inherent trade-offs.

Processing personal data for bias mitigation.

Technical approaches to mitigate algorithmic bias.

How are solely automated decision-making and relevant safeguards linked to fairness, and key questions to ask when considering Article 22 of the UK GDPR.

Annex A: Fairness in the AI lifecycle

Change overview : This is a new chapter with new content

This section is about data protection fairness considerations across the AI lifecycle, from problem formulation to decommissioning. It sets out why fundamental aspects of building AI such as underlying assumptions,

abstractions used to model a problem, the selection of target variables or the tendency to over-rely on quantifiable proxies may have an impact on fairness. This chapter also explains the different sources of bias that can lead to unfairness and possible mitigation measures. Technical terms are also explained in the updated glossary.

Glossary

Change overview : This is an old chapter with old and new content.

What you need to know:

New additions include definitions of:

Affinity groups, algorithmic fairness, algorithmic fairness constraints, bias mitigation algorithm, causality, confidence interval, correlation, cost function, dataset labellers, decision, construct and observed space, decision boundary, decision tree, downstream effects, ground truth, inductive bias, in-processing, hyperparameters, multi-criteria optimisation, objective function, post-processing bias mitigation, regularisation, redundant encodings, reward function, use case, target variable, variance.

Back to top

ICO AI and Data Protection - Transparency

URL: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/how-do-we-ensure-transparency-in-ai/>

How do we ensure transparency in AI? | ICO Skip to main content Home The ICO exists to empower you through information. Search Search Search Menu

How do we ensure transparency in AI?

Contents

Search this document Click to toggle details Latest updates

15 March 2023 - This is a new chapter with new content new high-level content on the transparency principle as it applies to AI. The main guidance on transparency and explainability resides within our existing Explaining Decisions Made with AI product.

What are our transparency obligations towards people?

You need to be transparent about how you process personal data in an AI system, to comply with the principle of transparency.

Before you begin your processing, you must consider your transparency obligations towards individuals whose personal data you plan to process. The core issues about AI and the transparency principle are addressed in 'Explaining decisions made with AI' guidance, so are not discussed in detail here

At a high level, you need to include the following in the privacy information:

your purposes for processing their personal data;

your retention periods for that personal data; and

who you will share it with.

If you collect data directly from individuals, you must provide that privacy information to them at the time you collect it, before you use it to train a model or apply that model on those individuals. If you collect it from other sources, you must provide this information within a reasonable period and no later than one month, or even earlier if you contact that person or disclose that data to someone else.

We have published the guidance on Explaining Decisions Made with AI that sets out how you can let people know how you use their data in your AI lifecycle. It offers good practice that can help you comply with the transparency principle.

Supplementary reading in ICO guidance

Explaining decisions made with AI

What is Transparency?

Right to be informed - What common issues might come up in practice?

Back to top

ICO AI and Data Protection - Lawfulness

URL: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/how-do-we-ensure-lawfulness-in-ai/>

How do we ensure lawfulness in AI? | ICO Skip to main content Home The ICO exists to empower you through information. Search Search Search Menu

How do we ensure lawfulness in AI?

Contents

Search this document Click to toggle details Latest update - 28 October 2024

We have updated the reference to inferred special category data on this page to reflect the latest changes to the detailed special category data guidance on inferences. This is because the guidance no longer focuses on the certainty of an inference as a relevant factor to decide whether it counts as special category data. Our underlying policy position has not changed, but we're explaining it in a different way to make our position clearer.

At a glance

This section sets out what to consider when you decide on your lawful basis for processing personal data in the context of AI development and deployment. It also includes up-to-date content on the status of AI-driven inferences.

Who is this section for?

This section is aimed at compliance-focused roles, including senior management, who are responsible for ensuring the processing using AI is lawful, fair, and transparent. It will also be of interest for AI developers to help them understand what kind of data they are likely to have access to, depending on the purpose they are using it for.

In detail

What should we consider when deciding lawful bases?

How should we distinguish purposes between AI development and deployment?

Can we rely on consent?

Can we rely on performance of a contract?

Can we rely on legal obligation, public task or vital interests?

Can we rely on legitimate interests?

What about special category data and data about criminal offences?

Using AI systems to make inferences

What about inferences and affinity groups?

What should we consider when deciding lawful bases?

The development and deployment of AI systems involve processing personal data in different ways for different purposes. You must break down and separate each distinct processing operation, and identify the purpose and an appropriate lawful basis for each one, in order to comply with the principle of lawfulness.

Whenever you are processing personal data – whether to train a new AI system, or make predictions using an existing one – you must have an appropriate lawful basis to do so.

Different lawful bases may apply depending on your particular circumstances. However, some lawful bases may be more likely to be appropriate for the training and / or deployment of AI than others. In some cases, more than one lawful basis may be appropriate.

At the same time, you must remember that:

it is your responsibility to decide which lawful basis applies to your processing;

you must always choose the lawful basis that most closely reflects the true nature of your relationship with the individual and the purpose of the processing;

you should make this determination before you start your processing;

you should document your decision;

you cannot swap lawful bases at a later date without good reason;

you must include your lawful basis in your privacy notice (along with the purposes); and

if you are processing special categories of data you need both a lawful basis and an additional condition for processing.

Further reading outside this guidance

Read our guidance on lawful basis for processing .

How should we distinguish purposes between AI development and deployment?

In many cases, when determining your purpose(s) and lawful basis, it will make sense for you to separate the research and development phase (including conceptualisation, design, training and model selection) of AI systems from the deployment phase. This is because these are distinct and separate purposes, with different circumstances and risks.

Therefore, it may sometimes be more appropriate to choose different lawful bases for your AI development and deployment. For example, you need to do this when:

the AI system was developed for a general-purpose task, and you then deploy it in different contexts for different purposes. For example, a facial recognition system could be trained to recognise faces, but that functionality could be used for multiple purposes, such as preventing crime, authentication, and tagging friends in a social network. Each of these further applications might require a different lawful basis;

you implement an AI system from a third party, any processing of personal data undertaken by the developer will have been for a different purpose (eg to develop the system) to what you intend to use the system for, therefore you may need to identify a different lawful basis; and

processing of personal data for the purposes of training a model may not directly affect the individuals, but once the model is deployed, it may automatically make decisions which have legal or significant effects. This means the provisions on automated decision-making apply; as a result, a different range of available lawful bases may apply at the development and deployment stages.

The following sections outline some AI-related considerations for each of the UK GDPR's lawful bases. They do not consider Part 3 of the DPA (law enforcement processing) at this stage.

Can we rely on consent?

Consent may be an appropriate lawful basis in cases where you have a direct relationship with the individuals whose data you want to process.

However, you must ensure that consent is freely given, specific, informed and unambiguous, and involves a clear affirmative act on the part of the individuals.

The advantage of consent is that it can lead to more trust and buy-in from individuals when they are using your service. Providing individuals with control can also be a factor in your DPIAs.

However, for consent to apply, individuals must have a genuine choice about whether you can use their data. This may have implications depending on what you intend to do with the data – it can be difficult to ensure you collect valid consent for more complicated processing operations, such as those involved in AI. For example, the more things you want to do with the data, the more difficult it is to ensure that consent is genuinely specific and informed.

The key is that individuals understand how you are using their personal data and have consented to this use. For example, if you want to collect a wide range of features to explore different models to predict a variety of outcomes, consent may be an appropriate lawful basis, provided that you inform individuals about these activities and obtain valid consent.

Consent may also be an appropriate lawful basis for the use of an individual's data during deployment of an AI system (eg for purposes such as personalising the service or making a prediction or recommendation).

However, you should be aware that for consent to be valid, individuals must also be able to withdraw consent as easily as they gave it. If you are relying on consent as the basis of processing data with an AI system during deployment (eg to drive personalised content), you should be ready to accommodate the withdrawal of consent for this processing.

Further reading outside this guidance

Read our guidance on consent .

Further reading – European Data Protection Board

The European Data Protection Board (EDPB), which has replaced the Article 29 Working Party (WP29), includes representatives from the data protection authorities of each EU member state. It adopts guidelines for complying with the requirements of the EU version of the GDPR.

The EDPB has produced guidelines on consent .

EDPB guidelines are no longer directly relevant to the UK regime and are not binding under the UK regime. However, they may still provide helpful guidance on certain issues.

Can we rely on performance of a contract?

This lawful basis applies where the processing using AI is objectively necessary to deliver a contractual service to the relevant individual, or to take steps prior to entering into a contract at the individual's request (eg to provide an AI-derived quote for a service).

If there is a less intrusive way of processing their data to provide the same service, or if the processing is not in practice objectively necessary for the performance of the contract, then you cannot rely on this lawful basis for the processing of data with AI.

Furthermore, even if it is an appropriate ground for the use of the system, this may not be an appropriate ground for processing personal data to develop an AI system. If an AI system can perform well enough without being trained on the individual's personal data, performance of the contract does not depend on such processing. Since machine learning models are typically built using very large datasets, whether or not a single individual's data is included in the training data should have a negligible effect on the system's performance.

Similarly, even if you can use performance of a contract as a lawful basis to provide a quote prior to a contract, this does not mean you can also use it to justify using that data to develop the AI system.

You should also note that you are unlikely to be able to rely on this basis for processing personal data for purposes such as 'service improvement' of your AI system. This is because in most cases, collection of personal data about the use of a service, details of how users engage with that service, or for the development of new functions within that service are not objectively necessary for the provision of a contract. This is because the service can be delivered without such processing.

Conversely, use of AI to process personal data for purposes of personalising content may be regarded as necessary for the performance of a contract – but only in some cases. Whether this processing can be regarded as 'intrinsic' to your service depends on:

the nature of the service;

the expectations of individuals; and

whether you can provide your service without this processing (ie if the personalisation of content by means of an AI system is not integral to the service, you should consider an alternative lawful basis).

Further reading outside this guidance

Read our guidance on contracts .

Further reading – European Data Protection Board

EDPB guidelines on processing under Article 6(1)(b) in the context of online services .

Can we rely on legal obligation, public task or vital interests?

There are some examples in which the use of an AI system to process personal data may be a legal obligation . You may also be required to audit your AI systems to ensure they are compliant with various legislation (including but not limited to data protection), and this may involve processing of personal data. For example, to test how the system performs on different kinds of people. Such processing could rely on legal obligation as a basis, but this would only cover the auditing and testing of the system, not any other use of that data. You must be able to identify the obligation in question, either by reference to the specific legal provision or else by pointing to an appropriate source of advice or guidance that sets it out clearly.

Similarly, if you use AI as part of the exercise of your official authority, or to perform a task in the public interest set out by law, the necessary processing of personal data involved may be based on those grounds. This is likely to be relevant to public authorities using AI to deliver public services.

In a limited number of cases, the processing of personal data by an AI system might be based on protecting the vital interests of the individuals. For example, for emergency medical diagnosis of patients who are otherwise incapable of providing consent (eg processing an fMRI scan of an unconscious patient by an AI diagnostic system).

It is however very unlikely that vital interests could also provide a basis for developing an AI system, because this would rarely directly and immediately result in protecting the vital interests of those individuals, even if the models that are eventually built might later be used to save the lives of other individuals. For the development of potentially life-saving AI systems, it would be better to rely on other lawful bases.

Further reading outside this guidance

Read our guidance on:

legal obligation ;

vital interests ;

and public task .

Can we rely on legitimate interests?

Depending on your circumstances, you could base your processing of personal data for both development and ongoing use of AI on the legitimate interests lawful basis.

It is important to note that while legitimate interests is the most flexible lawful basis for processing, it is not always the most appropriate. For example, if the way you intend to use people's data would be unexpected or cause unnecessary harm. It also means you are taking on additional responsibility for considering and protecting people's rights and interests. You must also be able to demonstrate the necessity and proportionality of the processing.

Additionally, if you are a public authority you can only rely on legitimate interests if you are processing for a legitimate reason other than performing your tasks as a public authority.

There are three elements to the legitimate interests lawful basis, and it can help to think of these as the 'three-part test'. You need to:

identify a legitimate interest (the 'purpose test');

show that the processing is necessary to achieve it (the 'necessity test'); and

balance it against the individual's interests, rights and freedoms (the 'balancing test').

There can be a wide range of interests that constitute 'legitimate interests' in data protection law. These can be your own or those of third parties, as well as commercial or societal interests. However, the key is understanding that while legitimate interests may be more flexible, it comes with additional responsibilities. It requires you to assess the impact of your processing on individuals and be able to demonstrate that there is a compelling benefit to the processing.

You should address and document these considerations as part of your legitimate interests assessment (LIA). As described above, in the initial research and development phase of your AI system, your purposes may be quite broad, but as more specific purposes are identified, you may need to review your LIA accordingly (or identify a different lawful basis).

Example

An organisation seeks to rely on legitimate interests for processing personal data for the purposes of training a machine learning model.

Legitimate interests may allow the organisation the most room to experiment with different variables for its model.

However, as part of its legitimate interests assessment, the organisation has to demonstrate that the range of variables and models it intends to use is a reasonable approach to achieving its outcome.

It can best achieve this by properly defining all of its purposes and justifying the use of each type of data collected – this will allow the organisation to work through the necessity and balancing aspects of its LIA. Over time, as purposes are refined, the LIA is revisited.

For example, the mere possibility that some data might be useful for a prediction is not by itself sufficient for the organisation to demonstrate that processing this data is necessary for building the model.

Further reading outside this guidance

Read our guidance on legitimate interests .

We have also published a lawful basis assessment tool which you can use to help you decide what basis is appropriate for you, as well as a legitimate interests template (Word) .

What about special category data and data about criminal offences?

If you intend to use AI to process special category data or data about criminal offences, then you will need to ensure you comply with the requirements of Articles 9 and 10 of the UK GDPR, as well as the DPA 2018.

Special category data is personal data that needs more protection because it is sensitive. In order to process it you need a lawful basis under Article 6, as well as a separate condition under Article 9, although these do not have to be linked. For more detail, see our detailed guidance on special category data and ‘ How should we address risks of bias and discrimination ’.

Further reading outside this guidance

Read our guidance on special category data and on criminal offence data .

Using AI systems to make inferences

You may intend to use AI systems to:

guess or predict details about someone, using information from various sources; or

analyse and find correlations between datasets, and use these to categorise, profile or make predictions.

In other words, you may use AI systems to make inferences about individuals or groups. Whether an inference is personal data depends on whether it relates to an identified or identifiable individual.

It may also be possible for you to infer details about someone which fall within what constitutes special categories of data. Whether or not this counts as special category data and triggers Article 9 depends whether you are intentionally drawing that inference, or intentionally treating someone differently based on an inference.

That inference is likely to be special category data, if your use of AI means you:

can (or intend to) infer relevant information about an individual; or

intend to treat someone differently on the basis of the inference (even if it's not with a reasonable degree of certainty).

Further reading in ICO guidance

See our guidance on “ What is personal data ”, including:

What are identifiers and related factors?

What is the meaning of ‘relates to’?

What about inferences?

What about inferences and affinity groups?

Whether inferences about groups are personal data depends on the circumstances. For example, how easy it is to identify an individual through group membership.

AI systems may aim to make predictions based on patterns within a population. In this sense they may appear to solely concern groups. However, if your AI system involves making inferences about a group – creating affinity groups - and linking these to a specific individual, then data protection law applies at multiple stages of the processing. More specifically:

the development stage, involving processing of individuals’ personal data to train the model; and

the deployment stage, where you apply the results of the model to other individuals that were not part of the training dataset on the basis of its predictive features.

This means that even if an individual's personal data is not part of your training dataset, data protection law applies when you use that model on them. This is because it involves you processing their personal data to make a decision or prediction about them, using your model to do so.

It is also important that you don't just consider obvious and immediate tangible damage to people. But also more subtle intangible harms and how the system might affect people's rights and freedoms more generally. This includes any impact on society as a whole. For example, DPIAs require you to consider risks to rights and freedoms of all those that the system might affect.

Additionally, data protection by design requires you to take appropriate steps to:

implement the data protection principles effectively; and

integrate necessary safeguards into your processing at the design stage, and throughout the lifecycle.

In the context of AI, your data protection considerations therefore must include:

the individuals whose personal data you process to train your system; and

the impact your system has on the rights and freedoms of individuals and society once it is deployed.

If you use an affinity group to profile individuals, you need to comply with the data protection principles, including fairness.

Back to top

ICO AI and Data Protection - Accuracy

URL: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/what-do-we-need-to-know-about-accuracy-and-statistical-accuracy/>

What do we need to know about accuracy and statistical accuracy? | ICO Skip to main content Home The ICO exists to empower you through information. Search Search Search Menu

What do we need to know about accuracy and statistical accuracy?

Contents

Search this document Click to toggle details Latest updates

15 March 2023 - This is new chapter with old content. Following the restructuring under the data protection principles, the statistical accuracy content – that used to reside with the chapter 'What do we need to do to ensure lawfulness, fairness, and transparency in AI systems?' - has moved into a new chapter that will focus on the accuracy principle. Statistical accuracy continues to remain key for fairness but we felt it was more appropriate to host it under a chapter that focuses on the accuracy.

At a glance

Statistical accuracy refers to the proportion of answers that an AI system gets correct or incorrect.

This section explains the controls you can implement so that your AI systems are sufficiently statistically accurate to ensure that the processing of personal data complies with the fairness principle.

Who is this section for?

This section is aimed at technical specialists, who are best placed to assess the statistical accuracy of an AI system and what personal data is required to improve it. It will also be useful for those in compliance-focused roles to understand how statistical accuracy is linked to fairness.

In detail

What is the difference between accuracy in data protection law and 'statistical accuracy' in AI?

How should we define and prioritise different statistical accuracy measures?

What should we consider about statistical accuracy?

What should we do about statistical accuracy post-deployment?

What is the difference between accuracy in data protection law and 'statistical accuracy' in AI?

It is important to note that the word 'accuracy' has a different meaning in the contexts of data protection and AI. Accuracy in data protection is one of the fundamental principles, requiring you to ensure that personal data is accurate and, where necessary, kept up to date. It requires you to take all reasonable steps to make sure the personal data you process is not 'incorrect or misleading as to any matter of fact' and, where necessary, is corrected or deleted without undue delay.

Broadly, accuracy in AI (and, more generally, in statistical modelling) refers to how often an AI system guesses the correct answer, measured against correctly labelled test data. The test data is usually separated from the training data prior to training, or drawn from a different source (or both). In many contexts, the answers the AI system provides will be personal data. For example, an AI system might infer someone's demographic information or their interests from their behaviour on a social network.

So, for clarity, in this guidance, we use the terms:

'accuracy' to refer to the accuracy principle of data protection law; and

'statistical accuracy' to refer to the accuracy of an AI system itself.

Fairness, in a data protection context, generally means that you should handle personal data in ways that people would reasonably expect and not use it in ways that have unjustified adverse effects on them. Improving the 'statistical accuracy' of your AI system's outputs is one of your considerations to ensure compliance with the fairness principle.

Data protection's accuracy principle applies to all personal data, whether it is information about an individual used as an input to an AI system, or an output of the system. However, this does not mean that an AI system needs to be 100% statistically accurate to comply with the accuracy principle.

In many cases, the outputs of an AI system are not intended to be treated as factual information about the individual. Instead, they are intended to represent a statistically informed guess as to something which may be true about the individual now or in the future. To avoid such personal data being misinterpreted as factual, you should ensure that your records indicate that they are statistically informed guesses rather than facts. Your records should also include information about the provenance of the data and the AI system used to generate the inference.

You should also record if it becomes clear that the inference was based on inaccurate data, or the AI system used to generate it is statistically flawed in a way which may have affected the quality of the inference.

Similarly, if the processing of the incorrect inference may have an impact on them, an individual may request the inclusion of additional information in their record countering the incorrect inference. This helps ensure that any decisions taken on the basis of the potentially incorrect inference are informed by any evidence that it may be wrong.

The UK GDPR mentions statistical accuracy in the context of profiling and automated decision-making at Recital 71. This states organisations should put in place 'appropriate mathematical and statistical procedures' for the profiling of individuals as part of their technical measures. You should ensure any factors that may result in inaccuracies in personal data are corrected and the risk of errors is minimised.

If you use an AI system to make inferences about people, you need to ensure that the system is sufficiently statistically accurate for your purposes. This does not mean that every inference has to be correct, but you do need to factor in the possibility of them being incorrect and the impact this may have on any decisions that you may take on the basis of them. Failure to do this could mean that your processing is not compliant with the fairness principle. It may also impact on your compliance with the data minimisation principle, as personal data, which includes inferences, must be adequate and relevant for your purpose.

Your AI system therefore needs to be sufficiently statistically accurate to ensure that any personal data generated by it is processed lawfully and fairly.

However, overall statistical accuracy is not a particularly useful measure, and usually needs to be broken down into different measures. It is important to measure and prioritise the right ones. If you are in a compliance role and are unsure what these terms mean, you should consult colleagues in the relevant technical roles.

Further reading in this guidance

Model evaluation – How should we evaluate our model's statistical accuracy?

Further reading outside this guidance

Read our guidance on accuracy as well as our guidance on the rights to rectification and erasure .

European guidelines on automated decision-making and profiling .

How should we define and prioritise different statistical accuracy measures?

Statistical accuracy, as a general measure, is about how closely an AI system's predictions match the correct labels as defined in the test data.

For example, if an AI system is used to classify emails as spam or not spam, a simple measure of statistical accuracy is the number of emails that were correctly classified as spam or not spam, as a proportion of all the emails that were analysed.

However, such a measure could be misleading. For example, if 90% of all emails received to an inbox are spam, then you could create a 90% accurate classifier by simply labelling everything as spam. But this would defeat the purpose of the classifier, as no genuine email would get through.

For this reason, you should use alternative measures of statistical accuracy to assess how good a system is. If you are in a compliance role, you should work with colleagues in technical roles to ensure that you have in place appropriate measures of statistical accuracy given your context and the purposes of processing.

These measures should reflect the balance between two different kinds of errors:

a false positive or 'type I' error: these are cases that the AI system incorrectly labels as positive (eg emails classified as spam, when they are genuine); or

a false negative or 'type II' error: these are cases that the AI system incorrectly labels as negative when they are actually positive (eg emails classified as genuine, when they are actually spam).

It is important to strike the right balance between these two types of errors. There are more useful measures which reflect these two types of errors, including:

precision : the percentage of cases identified as positive that are in fact positive (also called 'positive predictive value'). For example, if nine out of 10 emails that are classified as spam are actually spam, the precision of the AI system is 90%; or

recall (or sensitivity) : the percentage of all cases that are in fact positive that are identified as such. For example, if 10 out of 100 emails are actually spam, but the AI system only identifies seven of them, then its recall is 70%.

There are trade-offs between precision and recall, which can be assessed using statistical measures. If you place more importance on finding as many of the positive cases as possible (maximising recall), this may come at the cost of some false positives (lowering precision).

In addition, there may be important differences between the consequences of false positives and false negatives on individuals, which could affect the fairness of the processing.

Example

If a CV filtering system being used to assist with selecting qualified candidates for an interview produces a false positive, then an unqualified candidate may be invited to interview, wasting the employer's and the applicant's

time unnecessarily.

If it produces a false negative, a qualified candidate will miss an employment opportunity and the organisation will miss a good candidate.

You should prioritise avoiding certain kinds of error based on the severity and nature of the risks.

In general, statistical accuracy as a measure depends on how possible it is to compare the performance of a system's outputs to some 'ground truth' (ie checking the results of the AI system against the real world). For example, a medical diagnostic tool designed to detect malignant tumours could be evaluated against high quality test data, containing known patient outcomes.

In some other areas, a ground truth may be unattainable. This could be because no high-quality test data exists or because what you are trying to predict or classify is subjective (eg whether a social media post is offensive). There is a risk that statistical accuracy is misconstrued in these situations, so that AI systems are seen as being highly statistically accurate even though they are reflecting the average of what a set of human labellers thought, rather than objective truth.

To avoid this, your records should indicate where AI outputs are not intended to reflect objective facts, and any decisions taken on the basis of such personal data should reflect these limitations. This is also an example of where you must take into account the accuracy principle – for more information, see our guidance on the accuracy principle, which refers to accuracy of opinions .

Finally, statistical accuracy is not a static measure. While it is usually measured on static test data (held back from the training data), in real life situations AI systems are applied to new and changing populations. Just because a system is statistically accurate about an existing population's data (eg customers in the last year), it may not continue to perform well if there is a change in the characteristics of that population or any other population who the system is applied to in future. Behaviours may change, either of their own accord, or because they are adapting in response to the system, and the AI system may become less statistically accurate with time.

This phenomenon is referred to in machine learning as 'concept / model drift', and various methods exist for detecting it. For example, you can measure the distance between classification errors over time; increasingly frequent errors may suggest drift.

You should regularly assess drift and retrain the model on new data where necessary. As part of your accountability responsibilities, you should decide and document appropriate thresholds for determining whether your model needs to be retrained, based on the nature, scope, context and purposes of the processing and the risks it poses. For example, if your model is scoring CVs as part of a recruitment exercise, and the kinds of skills candidates need in a particular job are likely to change every two years, you should anticipate assessing the need to re-train your fresh data at least that often.

In other application domains where the main features don't change so often (eg recognising handwritten digits), you can anticipate less drift. You will need to assess this based on your own circumstances.

Further reading inside this guidance

See ' What should we know about accuracy and statistical accuracy' .

Further reading outside this guidance

See our guidance on the accuracy principle .

See ' Learning under concept drift: an overview ' for a further explanation of concept drift.

What should we consider about statistical accuracy?

You should always think carefully from the start whether it is appropriate to automate any prediction or decision-making process. This should include assessing the effectiveness of the AI system in making statistically accurate predictions about the individuals whose personal data it processes.

You should assess the merits of using a particular AI system in light of consideration of its effectiveness in making statistically accurate, and therefore valuable, predictions. Not all AI systems demonstrate a sufficient level of statistical accuracy to justify their use.

If you decide to adopt an AI system, then to comply with the data protection principles, you should:

ensure that all functions and individuals responsible for its development, testing, validation, deployment, and monitoring are adequately trained to understand the associated statistical accuracy requirements and measures;

make sure data is clearly labelled as inferences and predictions, and is not claimed to be factual;

ensure you have managed trade-offs and reasonable expectations; and

adopt a common terminology that staff can use to discuss statistical accuracy performance measures, including their limitations and any adverse impact on individuals.

What should we do about statistical accuracy post-deployment?

As part of your obligation to implement data protection by design and by default, you should consider statistical accuracy and the appropriate measures to evaluate it from the design phase and test these measures throughout the AI lifecycle. After deployment, you should implement monitoring, the frequency of which should be proportional to the impact an incorrect output may have on individuals. The higher the impact the more frequently you should monitor and report on it. You should also review your statistical accuracy measures regularly to mitigate the risk of concept drift. Your change policy procedures should take this into account from the outset.

Statistical accuracy is also an important consideration if you outsource the development of an AI system to a third party (either fully or partially) or purchase an AI solution from an external vendor. In these cases, you should examine and test any claims made by third parties as part of the procurement process.

Similarly, you should agree regular updates and reviews of statistical accuracy to guard against changing population data and concept/ model drift. If you are a provider of AI services, you should ensure that they are designed in such a way as to allow organisations to fulfil their data protection obligations.

Finally, the vast quantity of personal data you may hold and process as part of your AI systems is likely to put pressure on any pre-existing non-AI processes you use to identify and, if necessary, rectify/ delete inaccurate personal data, whether it is used as input or training/ test data. Therefore, you need to review your data governance practices and systems to ensure they remain fit for purpose.

Back to top

ICO AI and Data Protection - Security and Data Minimisation

URL: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/how-should-we-assess-security-and-data-minimisation-in-ai/>

How should we assess security and data minimisation in AI? | ICO Skip to main content Home The ICO exists to empower you through information. Search Search Search Menu

How should we assess security and data minimisation in AI?

Contents

Search this document

At a glance

This section explains how AI systems can exacerbate known security risks and make them more difficult to manage. It also presents the challenges for compliance with the data minimisation principle. A number of techniques are presented to help both data minimisation and effective AI development and deployment

Who is this section for?

This section is aimed at technical specialists, who are best placed to assess the security of an AI system and what personal data is required. It will also be useful for those in compliance-focused roles to understand the risks

associated with security and data minimisation in AI.

In detail

What security risks does AI introduce?

What types of privacy attacks apply to AI models?

What steps should we take to manage the risks of privacy attacks on AI models?

What data minimisation and privacy-preserving techniques are available for AI systems?

What security risks does AI introduce?

You must process personal data in a manner that ensures appropriate levels of security against its unauthorised or unlawful processing, accidental loss, destruction or damage. In this section we focus on the way AI can adversely affect security by making known risks worse and more challenging to control.

What are our security requirements?

There is no 'one-size-fits-all' approach to security. The appropriate security measures you should adopt depend on the level and type of risks that arise from specific processing activities.

Using AI to process any personal data has important implications for your security risk profile, and you need to assess and manage these carefully.

Some implications may be triggered by the introduction of new types of risks, eg adversarial attacks on machine learning models (see section 'What types of privacy attacks apply to AI models?').

Further reading outside this guidance

Read our guidance on security in the Guide to the UK GDPR, and the ICO/NCSC Security Outcomes , for general information about security under data protection law.

Information security is a key component of our AI auditing framework but is also central to our work as the information rights regulator. The ICO is planning to expand its general security guidance to take into account the additional requirements set out in the new UK GDPR.

While this guidance will not be AI-specific, it will cover a range of topics that are relevant for organisations using AI, including software supply chain security and increasing use of open-source software.

What is different about security in AI compared to 'traditional' technologies?

Some of the unique characteristics of AI mean compliance with data protection law's security requirements can be more challenging than with other, more established technologies, both from a technological and human perspective.

From a technological perspective, AI systems introduce new kinds of complexity not found in more traditional IT systems that you may be used to using. Depending on the circumstances, your use of AI systems is also likely to rely heavily on third party code relationships with suppliers, or both. Also, your existing systems need to be integrated with several other new and existing IT components, which are also intricately connected. Since AI systems operate as part of a larger chain of software components, data flows, organisational workflows and business processes, you should take a holistic approach to security. This complexity may make it more difficult to identify and manage some security risks, and may increase others, such as the risk of outages.

From a human perspective, the people involved in building and deploying AI systems are likely to have a wider range of backgrounds than usual, including traditional software engineering, systems administration, data scientists, statisticians, as well as domain experts.

Security practices and expectations may vary significantly, and for some there may be less understanding of broader security compliance requirements, as well as those of data protection law more specifically. Security of personal data may not always have been a key priority, especially if someone was previously building AI

applications with non-personal data or in a research capacity.

Further complications arise because common practices about how to process personal data securely in data science and AI engineering are still under development. As part of your compliance with the security principle, you should ensure that you actively monitor and take into account the state-of-the-art security practices when using personal data in an AI context.

It is not possible to list all known security risks that might be exacerbated when you use AI to process personal data. The impact of AI on security depends on:

the way the technology is built and deployed;

the complexity of the organisation deploying it;

the strength and maturity of the existing risk management capabilities; and

the nature, scope, context and purposes of the processing of personal data by the AI system, and the risks posed to individuals as a result.

The following hypothetical scenarios are intended to raise awareness of some of the known security risks and challenges that AI can exacerbate. The following content contains some technical details, so understanding how it may apply to your organisation may require attention of staff in both compliance and technical roles.

Our key message is that you should review your risk management practices ensuring personal data is secure in an AI context.

How should we ensure training data is secure?

ML systems require large sets of training and testing data to be copied and imported from their original context of processing, shared and stored in a variety of formats and places, including with third parties. This can make them more difficult to keep track of and manage.

Your technical teams should record and document all movements and storing of personal data from one location to another. This will help you apply appropriate security risk controls and monitor their effectiveness. Clear audit trails are also necessary to satisfy accountability and documentation requirements.

In addition, you should delete any intermediate files containing personal data as soon as they are no longer required, eg compressed versions of files created to transfer data between systems.

Depending on the likelihood and severity of the risk to individuals, you may also need to apply de-identification techniques to training data before it is extracted from its source and shared internally or externally.

For example, you may need to remove certain features from the data, or apply privacy enhancing technologies (PETs), before sharing it with another organisation.

How should we ensure security of externally maintained software used to build AI systems?

Very few organisations build AI systems entirely in-house. In most cases, the design, building, and running of AI systems will be provided, at least in part, by third parties that you may not always have a contractual relationship with.

Even if you hire your own ML engineers, you may still rely significantly on third-party frameworks and code libraries. Many of the most popular ML development frameworks are open source .

Using third-party and open source code is a valid option. Developing all software components of an AI system from scratch requires a large investment of time and resources that many organisations cannot afford, and especially compared to open source tools, would not benefit from the rich ecosystem of contributors and services built up around existing frameworks.

However, one important drawback is that these standard ML frameworks often depend on other pieces of software being already installed on an IT system. To give a sense of the risks involved, a recent study found the most popular ML development frameworks include up to 887,000 lines of code and rely on 137 external dependencies. Therefore, implementing AI will require changes to an organisation's software stack (and possibly

hardware) that may introduce additional security risks.

Example

The recruiter hires an ML engineer to build the automated CV filtering system using a Python-based ML framework. The ML framework depends on a number of specialist open-source programming libraries, which needed to be downloaded on the recruiter's IT system.

One of these libraries contains a software function to convert the raw training data into the format required to train the ML model. It is later discovered the function has a security vulnerability. Due to an unsafe default configuration, an attacker introduced and executed malicious code remotely on the system by disguising it as training data.

This is not a far-fetched example, in January of 2019, such a vulnerability was discovered in 'NumPy', a popular library for the Python programming language used by many machine learning developers.

What should we do in this situation?

Whether AI systems are built in-house, externally, or a combination of both, you will need to assess them for security risks. As well as ensuring the security of any code developed in-house, you need to assess the security of any externally maintained code and frameworks.

In many respects, the standard requirements for maintaining code and managing security risks will apply to AI applications. For example:

your external code security measures should include subscribing to security advisories to be notified of vulnerabilities; or

your internal code security measures should include adhering to coding standards and instituting source code review processes.

Whatever your approach, you should ensure that your staff have appropriate skills and knowledge to address these security risks.

Having a secure pipeline from development to deployment will further mitigate security risks associated with third party code by separating the ML development environment from the rest of your IT infrastructure where possible. Using 'virtual machines' or 'containers' - emulations of a computer system that run inside, but isolated from the rest of the IT system may help here; these can be pre-configured specifically for ML tasks. In addition, it is possible to train an ML model using a programming language and framework suitable for exploratory development, but then convert the model into another more secure format for deployment.

Further reading outside this guidance

Read our report on Protecting personal data in online services: learning from the mistakes of others for more information. Although written in 2014, the report's content in this area may still assist you.

The ICO is developing further security guidance, which will include additional recommendations for the oversight and review of externally maintained source code from a data protection perspective, as well as its implications for security and data protection by design.

National Cyber Security Centre (NCSC) guidance on maintaining code repositories .

What types of privacy attacks apply to AI models?

The personal data of the people who an AI system was trained on might be inadvertently revealed by the outputs of the system itself.

It is normally assumed that the personal data of the individuals whose data was used to train an AI system cannot be inferred by simply observing the predictions the system returns in response to new inputs. However, new types of privacy attacks on ML models suggest that this is sometimes possible.

In this section, we focus on two kinds of these privacy attacks – 'model inversion' and 'membership inference'.

What are model inversion attacks?

In a model inversion attack, if attackers already have access to some personal data belonging to specific individuals included in the training data, they can infer further personal information about those same individuals by observing the inputs and outputs of the ML model. The information attackers can learn about goes beyond generic inferences about individuals with similar characteristics.

Example one – model inversion attack

An early demonstration of this kind of attack concerned a medical model designed to predict the correct dosage of an anticoagulant, using patient data including genetic biomarkers. It proved that an attacker with access to some demographic information about the individuals included in the training data could infer their genetic biomarkers from the model, despite not having access to the underlying training data.

Further reading outside this guidance

For further details of a model inversion attack, see 'Algorithms that remember: model inversion attacks and data protection law'.

Example two – model inversion attack

Another recent example demonstrates that attackers could reconstruct images of faces that a Facial Recognition Technology (FRT) system has been trained to recognise. FRT systems are often designed to allow third parties to query the model. When the model is given the image of a person whose face it recognises, the model returns its best guess as to the name of the person, and the associated confidence rate.

Attackers could probe the model by submitting many different, randomly generated face images. By observing the names and the confidence scores returned by the model, they could reconstruct the face images associated with the individuals included in the training data. While the reconstructed face images were imperfect, researchers found that they could be matched (by human reviewers) to the individuals in the training data with 95% accuracy (see Figure 2.)

Figure 2. A face image recovered using model inversion attack (left) and corresponding training set image (right), from Fredriksen et al., 'Model Inversion Attacks that Exploit Confidence Information'.

What are membership inference attacks?

Membership inference attacks allow malicious actors to deduce whether a given individual was present in the training data of a ML model. However, unlike in model inversion, they don't necessarily learn any additional personal data about the individual.

For example, if hospital records are used to train a model which predicts when a patient will be discharged, attackers could use that model in combination with other data about a particular individual (that they already have) to work out if they were part of the training data. This would not reveal any individual's data from the training data set itself, but in practice it would reveal that they had visited one of the hospitals that generated the training data during the period the data was collected.

Similar to the earlier FRT example, membership inference attacks can exploit confidence scores provided alongside a model's prediction. If an individual was in the training data, then the model will be disproportionately confident in a prediction about that person because it has seen them before. This allows the attacker to infer that the person was in the training data.

The gravity of the consequences of models' vulnerability to membership inference will depend on how sensitive or revealing membership might be. If a model is trained on a large number of people drawn from the general population, then membership inference attacks pose less risk. But if the model is trained on a vulnerable or sensitive population (eg patients with dementia, or HIV), then merely revealing that someone is part of that population may be a serious privacy risk.

What are black box and white box attacks?

There is an important distinction between 'black box' and 'white box' attacks on models. These two approaches correspond to different operational models.

In white box attacks, the attacker has complete access to the model itself, and can inspect its underlying code and properties (although not the training data). For example, some AI providers give third parties an entire pre-trained model and allow them to run it locally. White box attacks enable additional information to be gathered, such as the type of model and parameters used, which could help an attacker in inferring personal data from the model.

In black box attacks, the attacker only has the ability to query the model and observe the relationships between inputs and outputs. For example, many AI providers enable third parties to access the functionality of an ML model online to send queries containing input data and receive the model's response. The examples we have highlighted above are both black box attacks.

White and black box attacks can be performed by providers' customers or anyone else with either authorised or unauthorised access to either the model itself, or its query or response functionality.

What about models that include training data by design?

Model inversion and membership inferences show that AI models can inadvertently contain personal data. You should also note that there are certain kinds of ML models which actually contain parts of the training data in its raw form within them by design. For example, 'support vector machines' (SVMs) and 'k-nearest neighbours' (KNN) models contain some of the training data in the model itself.

In these cases, if the training data is personal data, access to the model by itself means that the organisation purchasing the model will already have access to a subset of the personal data contained in the training data, without having to exert any further efforts. Providers of such ML models, and any third parties procuring them, should be aware that they may contain personal data in this way.

Unlike model inversion and membership inference, personal data contained in models like this is not an attack vector. Any personal data contained in these models would be there by design and easily retrievable by the third party. Storing and using these models therefore constitutes processing of personal data and as such, the standard data protection provisions apply.

Further reading outside this guidance

See scikit learn's module on 'Support Vector Machines'.

See scikit learn's module on 'K-nearest Neighbours'.

What steps should we take to manage the risks of privacy attacks on AI models?

If you train models and provide them to others, you should assess whether those models may contain personal data or are at risk of revealing it if attacked, and take appropriate steps to mitigate these risks.

You should assess whether the training data contains identified or identifiable personal data of individuals, either directly or by those who may have access to the model. You should assess the means that may be reasonably likely to be used, in light of the vulnerabilities described above. As this is a rapidly developing area, you should stay up-to-date with the state of the art in both methods of attack and mitigation.

Security and ML researchers are still working to understand what factors make ML models more or less vulnerable to these kinds of attacks, and how to design effective protections and mitigation strategies.

One possible cause of ML models being vulnerable to privacy attacks is known as 'overfitting'. This is where the model pays too much attention to the details of the training data, effectively almost remembering particular examples from the training data rather than just the general patterns. Overfitting can happen where there are too many features included or where there are too few examples in the training data (or both). Model inversion and membership inference attacks can exploit this.

Avoiding overfitting will help, both in mitigating the risk of privacy attacks and also in ensuring that the model is able to make good inferences on new examples it hasn't seen before. However, avoiding overfitting will not completely eliminate the risks. Even models which are not overfitted to the training data can still be vulnerable to privacy attacks.

In cases where confidence information provided by a ML system can be exploited, as in the FRT example above, the risk could be mitigated by not providing it to the end user. This would need to be balanced against the need

for genuine end users to know whether or not to rely on its output and will depend on the particular use case and context.

If you are going to provide a whole model to others via an Application Programming Interface (API), you will not be subject to white box attacks in this way, because the API's users will not have direct access to the model itself. However, you might still be subjected to black box attacks.

To mitigate this risk, you could monitor queries from the API's users, in order to detect whether it is being used suspiciously. This may indicate a privacy attack and would require prompt investigation, and potential suspension or blocking of a particular user account. Such measures may become part of common real-time monitoring techniques used to protect against other security threats, such as 'rate-limiting' (reducing the number of queries that can be performed by a particular user in a given time limit).

If your model is going to be provided in whole to a third party, rather than being merely accessible to them via an API, then you will need to consider the risk of 'white box' attacks. As the model provider, you will be less easily able to monitor the model during deployment and thereby assess and mitigate the risk of privacy attacks on it.

However, you remain responsible for assessing and mitigating the risk that personal data used to train your models may be exposed as a result of the way your clients have deployed the model. You may not be able to fully assess this risk without collaborating with your clients to understand the particular deployment contexts and associated threat models.

As part of your procurement policy there should be sufficient information sharing between each party to perform your respective assessments as necessary. In some cases, ML model providers and clients will be joint controllers and therefore need to perform a joint risk assessment.

In cases where the model actually contains examples from the training data by default (as in SVMs and KNNs), this is a transfer of personal data, and you should treat it as such.

What about AI security risks raised by explainable AI?

Recent research has demonstrated how some proposed methods to make ML models explainable can unintentionally make it easier to conduct privacy attacks on models. For example, when providing an explanation to individuals, there may be a risk that doing so reveals proprietary information about how the AI model works. However, you must take care not to conflate commercial interests with data protection requirements (eg commercial security and data protection security), and instead you should consider the extent to which such a trade-off genuinely exists.

Given that the kind of explanations you may need to provide to data subjects about AI need to be 'in a concise, transparent, intelligible and easily accessible form, using clear and plain language', they will not normally risk commercially sensitive information. However, there may be cases where you need to consider the right of individuals to receive an explanation, and (for example) the interests of businesses to maintain trade secrets, noting that data protection compliance cannot be 'traded away'.

Both of these risks are active areas of research, and their likelihood and severity are the subject of debate and investigation. We will continue to monitor and review these risks and may update this guidance accordingly.

Further reading outside this guidance

ICO and The Alan Turing Institute guidance on 'Explaining decisions made with artificial intelligence'.

What about adversarial examples?

While the main data protection concerns about AI involve accidentally revealing personal data, there are other potential novel AI security risks, such as 'adversarial examples'.

These are examples fed to an ML model, which have been deliberately modified so that they are reliably misclassified. These can be images which have been manipulated, or even real-world modifications such as stickers placed on the surface of the item. Examples include pictures of turtles which are classified as guns, or road signs with stickers on them, which a human would instantly recognise as a 'STOP', but an image recognition model does not.

While such adversarial examples are concerning from a security perspective, they might not raise data protection concerns if they don't involve personal data. The security principle refers to security of the personal data – protecting it against unauthorised processing. However, adversarial attacks don't necessarily involve unauthorised processing of personal data, only a compromise to the system.

However, there may be cases in which adversarial examples can be a risk to the rights and freedoms of individuals. For example, some attacks have been demonstrated on facial recognition systems. By slightly distorting the face image of one individual, an adversary can trick the facial recognition system into misclassifying them as another (even though a human would still recognise the distorted image as the correct individual). This would raise concerns about the system's statistical accuracy, especially if the system is used to make legal or similarly significant decisions about individuals.

You may also need to consider the risk of adversarial examples as part of your obligations under the Network and Information Systems Regulations 2018 (NIS). The ICO is the competent authority for 'relevant digital service providers' under NIS. These include online search engines, online marketplaces and cloud computing services. A 'NIS incident' includes incidents which compromise the data stored by network and information systems and the related services they provide. This is likely to include AI cloud computing services. So, even if an adversarial attack does not involve personal data, it may still be a NIS incident and therefore within the ICO's remit.

Further reading outside this guidance

Read our Guide to NIS .

For further information on adversarial attacks on facial recognition systems, see ' Efficient decision-based black-box adversarial attacks on face recognition' .

What data minimisation and privacy-preserving techniques are available for AI systems?

What considerations about the data minimisation principle do we need to make?

The data minimisation principle requires you to identify the minimum amount of personal data you need to fulfil your purpose, and to only process that information, and no more. For example, Article 5(1)(c) of the UK GDPR says

'1. Personal data shall be

adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed (data minimisation)'

However, AI systems generally require large amounts of data. At first glance it may therefore be difficult to see how AI systems can comply with the data minimisation principle, yet if you are using AI as part of your processing, you are still required to do so.

Whilst it may appear challenging, in practice this may not be the case. The data minimisation principle does not mean either 'process no personal data' or 'if we process more, we're going to break the law'. The key is that you only process the personal data you need for your purpose.

How you go about determining what is 'adequate, relevant and limited' is therefore going to be specific to your circumstances, and our existing guidance on data minimisation details the steps you should take.

In the context of AI systems, what is 'adequate, relevant and limited' is therefore also case specific. However, there are a number of techniques that you can adopt in order to develop AI systems that process only the data you need, while still remaining functional.

In this section, we explore some of the most relevant techniques for supervised Machine Learning (ML) systems, which are currently the most common type of AI in use.

Within your organisations, the individuals accountable for the risk management and compliance of AI systems need to be aware that such techniques exist and be able to discuss and assess different approaches with your technical staff. For example, the default approach of data scientists in designing and building AI systems might involve collecting and using as much data as possible, without thinking about ways they could achieve the same purposes with less data.

You must therefore implement risk management practices designed to ensure that data minimisation, and all relevant minimisation techniques, are fully considered from the design phase. Similarly, if you buy in AI systems or implement systems operated by third parties (or both), these considerations should form part of the procurement process due diligence.

You should also be aware that, while they may help you comply with the principle of data minimisation, the techniques described here do not eliminate other kinds of risk.

Also, while some techniques will not require any compromise to comply with data minimisation requirements, others may need you to balance data minimisation with other compliance or utility objectives. For example, making more statistically accurate and non-discriminatory ML models.

The first step you should take towards compliance with data minimisation is to understand and map out all the ML processes in which personal data might be used.

Further reading outside this guidance

Read our guidance on the data minimisation principle

How should we process personal data in supervised ML models?

Supervised ML algorithms can be trained to identify patterns and create models from datasets ('training data') which include past examples of the type of instances the model will be asked to classify or predict. Specifically, the training data contains both the 'target' variable (ie the thing that the model is aiming to predict or classify), and several 'predictor' variables (ie the input used to make the prediction).

For example, in the training data for a bank's credit risk ML model, the predictor variables might include the age, income, occupation, and location of previous customers, while the target variable will be whether or not the customers repaid their loan.

Once trained, ML systems can then classify and make predictions based on new data containing examples that the system has never seen before. A query is sent to the ML model, containing the predictor variables for a new instance (eg a new customer's age, income, occupation). The model responds with its best guess as to the target variable for this new instance (eg whether or not the new customer will default on a loan).

Supervised ML approaches therefore use data in two main phases:

the training phase , when training data is used to develop models based on past examples; and

the inference phase , when the model is used to make a prediction or classification about new instances.

If the model is used to make predictions or classifications about individual people, then it is very likely that personal data will be used at both the training and inference phases.

What techniques should we use to minimise personal data when designing ML applications?

When designing and building ML applications, data scientists will generally assume that all data used in training, testing and operating the system will be aggregated in a centralised way, and held in its full and original form by a single entity in multiple places throughout the AI system's lifecycle.

However, where this is personal data, you need to consider whether it is necessary to process it for your purpose(s). If you can achieve the same outcome by processing less personal data then by definition, the data minimisation principle requires you to do so.

A number of techniques exist which can help you to minimise the amount of personal data you need to process.

How should we minimise personal data in the training stage?

As we have explained, the training phase involves applying a learning algorithm to a dataset containing a set of features for each individual which are used to generate the prediction or classification.

However, not all features included in a dataset will necessarily be relevant to your purpose. For example, not all financial and demographic features will be useful to predict credit risk. Therefore, you need to assess which

features – and therefore what data – are relevant for your purpose, and only process that data.

There are a variety of standard feature selection methods used by data scientists to select features which will be useful for inclusion in a model. These methods are good practice in data science, but they also go some way towards meeting the data minimisation principle.

Also, as discussed in the ICO's previous report on AI and Big Data, the fact that some data might later in the process be found to be useful for making predictions is not enough to establish why you need to keep it for this purpose, nor does it retroactively justify its collection, use, or retention. You must not collect personal data on the off-chance that it might be useful in the future, although you may be able to hold information for a foreseeable event that may not occur, but only if you are able to justify it.

How should we balance data minimisation and statistical accuracy?

In general, when an AI system learns from data (as is the case with ML models), the more data it is trained on, the more statistically accurate it will be. That is, the more likely it will capture any underlying, statistically useful relationships between the features in the datasets. As explained in the section on 'What do we need to do about statistical accuracy?', the fairness principle means that your AI system needs to be sufficiently statistically accurate for your purposes.

For example, a model for predicting future purchases based on customers' purchase history would tend to be more statistically accurate the more customers are included in the training data. And any new features added to an existing dataset may be relevant to what the model is trying to predict. For example, purchase histories augmented with additional demographic data might further improve the statistical accuracy of the model.

However, generally speaking, the more data points collected about each person, and the more people whose data is included in the data set, the greater the risks to those individuals, even if the data is collected for a specific purpose. The principle of data minimisation requires you not to use more data than is necessary for your purposes. So if you can achieve sufficient accuracy with fewer data points or fewer individuals being included (or both), you should do so.

Further reading outside this guidance

Read our report on Big data, artificial intelligence, machine learning and data protection

What privacy-enhancing methods should we consider?

There are also a range of techniques for enhancing privacy which you can use to minimise the personal data being processed at the training phase, including:

perturbation or adding 'noise';

synthetic data; and

federated learning

Some of these techniques involve modifying the training data to reduce the extent to which it can be traced back to specific individuals, while retaining its use for the purposes of training well-performing models.

You can apply these types of privacy-enhancing techniques to the training data after you have already collected it. Where possible, however, you should apply them before collecting any personal data, as a part of mitigating the risks to individuals that large datasets can pose.

You can mathematically measure the effectiveness of these privacy-enhancing techniques in balancing the privacy of individuals and the utility of a ML system, using methods such as differential privacy.

Differential privacy is a way to measure whether a model created by an ML algorithm significantly depends on the data of any particular individual used to train it. While mathematically rigorous in theory, meaningfully implementing differential privacy in practice is still challenging.

You should monitor developments in these methods and assess whether they can provide meaningful data minimisation before attempting to implement them. They may not be appropriate or sufficiently mature to deploy in your particular context.

Perturbation

Modification could involve changing the values of data points belonging to individuals at random (known as 'perturbing' or adding 'noise' to the data) in a way that preserves some of the statistical properties of those features.

Generally speaking, you can choose how much noise to inject, with obvious consequences for how much you can still learn from the 'noisy data'.

For example, smartphone predictive text systems are based on the words that users have previously typed. Rather than always collecting a user's actual keystrokes, the system could be designed to create 'noisy' (ie false) words at random. This means it makes it substantially less certain which words were 'noise' and which words were actually typed by a specific user.

Although data would be less accurate at individual level, provided the system has enough users, you could still observe patterns, and use these to train your ML model at an aggregate level. The more noise you inject, the less you can learn from the data, but in some cases you may be able to inject sufficient noise to render the data pseudonymous in a way which provides a meaningful level of protection.

Synthetic data

In some cases, you may be able to develop models using 'synthetic' data. This is data which does not relate to real people, but has been generated artificially. To the extent that synthetic data cannot be related to identified or identifiable living individuals, it is not personal data and therefore data protection obligations do not apply when you process it.

However, you will generally need to process some real data in order to determine realistic parameters for the synthetic data. Where that real data can be related to identified or identifiable individuals, then the processing of such data must comply with data protection laws.

Furthermore, in some cases, it may be possible to infer information about the real data which was used to estimate those realistic parameters, by analysing the synthetic data. For example, if the real data contains a single individual who is unusually tall, rich, and old, and your synthetic data contains a similar individual (in order to make the overall dataset statistically realistic), it may be possible to infer that the individual was in the real dataset by analysing the synthetic dataset. Avoiding such re-identification may require you to change your synthetic data to the extent that it would be too unrealistic to be useful for machine learning purposes.

Federated learning

A related privacy-preserving technique is federated learning. This allows multiple different parties to train models on their own data ('local' models). They then combine some of the patterns that those models have identified (known as 'gradients') into a single, more accurate 'global' model, without having to share any training data with each other.

Federated learning is relatively new but has several large-scale applications. These include auto-correction and predictive text models across smartphones, but also for medical research involving analysis across multiple patient databases.

While sharing the gradient derived from a locally trained model presents a lower privacy risk than sharing the training data itself, a gradient can still reveal some personal information about the individuals it was derived from, especially if the model is complex with a lot of fine-grained variables. You therefore still need to assess the risk of re-identification. In the case of federated learning, participating organisations may be considered joint controllers even though they don't have access to each other's data.

Further reading inside this guidance

For more information on controllership in AI, read the section on controller/processor relationships.

Further reading outside this guidance

See ' Rappor (randomised aggregatable privacy preserving ordinal responses) ' for an example of perturbation.

For an introduction to differential privacy, see ‘Differential privacy: an introduction for statistical agencies’.

How should we minimise personal data at the inference stage?

To make a prediction or classification about an individual, ML models usually require the full set of predictor variables for that person to be included in the query. As in the training phase, there are a number of techniques which you can use to minimise personal data, or mitigate risks posed to that data, at the inference stage, including:

converting personal data into less ‘human readable’ formats;

making inferences locally; and

privacy-preserving query approaches.

We consider these approaches below.

Converting personal data into less “human readable” formats

In many cases the process of converting data into a format that allows it to be classified by a model can go some way towards minimising it. Raw personal data will usually first have to be converted into a more abstract format for the purposes of prediction. For example, human-readable words are normally translated into a series of numbers (called a ‘feature vector’).

This means that if you deploy an AI model you may not need to process the human-interpretable version of the personal data contained in the query. For example, if the conversion happens on the user’s device.

However, the fact that it is no longer easily human-interpretable does not imply that the converted data is no longer personal. Consider Facial Recognition Technology (FRT), for example. In order for a facial recognition model to work, digital images of the faces being classified have to be converted into ‘faceprints’. These are mathematical representations of the geometric properties of the underlying faces (eg the distance between a person’s nose and upper lip).

Rather than sending facial images themselves to your servers, photos could be converted to faceprints directly on the individuals’ device which captures them before sending them to the model for querying. These faceprints would be less easily identifiable to any humans than face photos.

However, faceprints are still personal (indeed, biometric) data and therefore very much identifiable within the context of the specific facial recognition models that they are created for. Also, when used for the purposes of uniquely identifying an individual, they would be special category data under data protection law.

Making inferences locally

Another way to minimise the personal data involved in prediction is to host the ML model on the device from which the query is generated and which already collects and stores the individual’s personal data. For example, an ML model could be installed on the user’s own device and make inferences ‘locally’, rather than being hosted on a cloud server.

For example, models for predicting what news content a user might be interested in could be run locally on their smartphone. When the user opens the news app the day’s news is sent to the phone and the local model would select the most relevant stories to show to the user, based on the user personal habits or profile information which are tracked and stored on the device itself and are not shared with the content provider or app store.

The constraint is that ML models need to be sufficiently small and computationally efficient to run on the user’s own hardware. However, recent advances in purpose-built hardware for smartphones and embedded devices mean that this is an increasingly viable option.

It is important to note that local processing is not necessarily out of scope of data protection law. Even if the personal data involved in training is being processed on the user’s device, the organisation which creates and distributes the model is still a controller in so far as it determines the means and purposes of processing.

Similarly, if personal data on the user’s device is subsequently accessed by a third party, this activity would constitute ‘processing’ of that data.

Privacy-preserving query approaches

If it is not feasible to deploy the model locally, other privacy-enhancing techniques exist to minimise the data that is revealed in a query sent to a ML model. These allow one party to retrieve a prediction or classification without revealing all of this information to the party running the model; in simple terms, they allow you to get an answer without having to fully reveal the question.

Further reading outside this guidance

See 'Privad: practical privacy in online advertising' and 'Targeted advertising on the handset: privacy and security challenges' for proof of concept examples for making inferences locally.

See 'TAPAS: trustworthy privacy-aware participatory sensing' for an example of privacy-preserving query approaches.

Does anonymisation have a role?

There are conceptual and technical similarities between data minimisation and anonymisation. In some cases, applying privacy-preserving techniques means that certain data used in ML systems is rendered pseudonymous or anonymous.

However, you should note that pseudonymisation is essentially a security and risk reduction technique, and data protection law still applies to personal data that has undergone pseudonymisation. In contrast, 'anonymous information' means that the information in question is no longer personal data and data protection law does not apply to it.

Further reading outside this guidance

Anonymisation

What should we do about storing and limiting training data?

Sometimes it may be necessary to retain training data in order to re-train the model, for example when new modelling approaches become available and for debugging. However, where a model is established and unlikely to be re-trained or modified, the training data may no longer be needed. If the model is designed to use only the last 12 months' worth of data, a data retention policy should specify that data older than 12 months be deleted.

Further reading outside this guidance

The European Union Agency for Cybersecurity (ENISA) has a number of publications about PETs, including research reports.

Back to top